

Login Security Fix Summary

Date: May 5, 2026

What Was Happening

The browser was showing a Supabase OAuth callback URL with `#access_token=...` in the address bar. That is the implicit OAuth flow. It can happen when Google/Supabase redirects back to the app but the app is not running, has not mounted yet, or fails before the auth callback cleanup code runs.

Any URL containing `'access_token'`, `'refresh_token'`, or `'provider_token'` should be treated as sensitive. Do not share it. If one has been exposed, sign out of that account or revoke the session in Supabase.

What Was Fixed

The app now scrubs OAuth callback parameters before React renders.

Added:

- `'src/lib/authCallback.ts'`
- early callback cleanup in `'src/main.tsx'`
- callback parameter consumption in `'src/context/AuthContext.tsx'`
- PKCE auth configuration in `'src/lib/supabase.ts'`

The early cleanup stores callback parameters briefly in `'sessionStorage'`, removes token-bearing values from the visible URL, then lets the auth provider complete the Supabase session exchange.

Why PKCE Matters

Supabase supports two browser auth callback styles:

- implicit flow: returns tokens in the URL fragment, such as `#access_token=...`
- PKCE flow: returns a short `?code=...` that the app exchanges for a session

The app is now configured for PKCE:

```
""ts
auth: {
  detectSessionInUrl: true,
  flowType: "pkce",
  persistSession: true,
  autoRefreshToken: true
}
""
```

This reduces token exposure in future redirects.

Deployment Pipeline

The intended path is:

```
"""text
local repo -> git -> Replit -> Sipopedia.com
"""
```

For that pipeline to stay connected, every environment needs the right public frontend variables and private backend secrets.

Required Production Environment Variables

Set these in Replit or the deployment environment:

```
"""text
VITE_APP_URL=https://sipopedia.com
VITE_SUPABASE_URL=https://your-project-ref.supabase.co
VITE_SUPABASE_ANON_KEY=your-anon-key
"""
```

Server-side or Edge Function secrets should remain private:

```
"""text
SUPABASE_URL=https://your-project-ref.supabase.co
SUPABASE_ANON_KEY=your-anon-key
SUPABASE_SERVICE_ROLE_KEY=<private-service-role-key>
GOOGLE_AI_API_KEY=<private-google-ai-key>
GOOGLE_MODEL=gemini-2.0-flash
"""
```

Never commit real values for private secrets.

Supabase Redirect URLs

Supabase Auth URL configuration should allow:

```
"""text
https://sipopedia.com
https://www.sipopedia.com
http://localhost:3000
http://127.0.0.1:5173
"""
```

Production should use 'https://sipopedia.com'. Local development can use 'localhost' only when the local dev server is running.

If testing on a temporary Replit URL, add that exact URL to Supabase Auth redirect URLs and do not set 'VITE_APP_URL' to a localhost URL.

Secret Handling Rules

Safe to expose in frontend:

- 'VITE_APP_URL'
- 'VITE_SUPABASE_URL'
- 'VITE_SUPABASE_ANON_KEY'
- 'VITE_CHECKOUT_URL'
- 'VITE_SALES_EMAIL'

Keep private:

- 'SUPABASE_SERVICE_ROLE_KEY'
- 'GOOGLE_AI_API_KEY'
- OAuth client secrets
- downloaded OAuth JSON files
- billing webhook secrets
- any file containing real tokens

Verification Completed

The fix was validated with:

```
""text
npm run build
powershell -File .\validators\validate-website.ps1 -SkipInstall
npm run security:secrets
""
```

All passed before the fix was pushed.

Git Result

The fix was pushed to 'main' in commit:

```
""text
1a4efd3 Harden Supabase auth callback handling
""
```

Operational Checklist

Before publishing:

1. Confirm Replit has 'VITE_APP_URL=https://sipopedia.com'.
2. Confirm Replit has the current Supabase frontend variables.
3. Confirm Supabase Edge Function secrets are stored in Supabase/Replit secret stores, not git.
4. Confirm Supabase Auth redirect URLs include 'https://sipopedia.com'.
5. Publish from the latest 'main'.
6. Test Google login on 'https://sipopedia.com'.

7. Verify the browser URL does not show 'access_token', 'refresh_token', or 'provider_token'.